BreachMirror AI

Security Awareness & Preventive Controls

Version 3.0 | September 2026 | Prepared for the BreachMirror AI Product Team

Change Log

Version	Date	Change
1.0	Aug 2026	Initial BreachMirror AI concept: real-time detection and blocking of risky user actions.
2.0	Sep 2026	Added Security Awareness & Preventive Controls section, condensed the risk categories into a single reference table, added the Agile backlog and documentation-versioning approach, and added the clickable alert/scoring prototype.
3.0	Sep 2026	Added the Automated Breach Detection & Classification Engine and a Breach Type taxonomy; added risk category 11 (company-issued-laptop-only, including Ethernet/HDMI bridging); updated the prototype with live breach-type classification and a device-compliance scenario.

1. Purpose

Most security breaches trace back to accidental human error rather than malicious intent. New internees can unknowingly expose organizational data through everyday, well-intentioned habits — pasting code into a chatbot, saving a file to a personal drive, borrowing a USB stick, or working from a personal laptop. BreachMirror AI is an application that runs continuously on the company laptop: it doesn't only detect risky behavior, it automatically classifies what kind of breach is unfolding and explains, in the moment, why the action is dangerous — turning every near-miss into a short lesson instead of a silent block.

2. Automated Breach Detection & Classification Engine

BreachMirror AI watches endpoint, network, and account telemetry continuously — it doesn't wait for a person to report an incident. The moment a monitored action crosses a risk threshold, the engine both detects that a breach is occurring and classifies exactly what type it is, so the response and the record are specific rather than generic.

2.1 Detection Pipeline

1. Monitor — process execution, network egress, file movement, device connections, and authentication events on the company laptop, continuously and in the background.
2. Detect — compare activity against known-risky patterns (Section 3) and flag the moment one is crossed.
3. Classify — assign the event a Breach Type from the taxonomy below, using the specific signal that triggered it.
4. Respond — trigger the matching BreachMirror AI action (block, warn, redirect) in real time.
5. Score & Log — apply the awareness-score impact (Section 5) and write the event, with its breach type, to the activity log.

2.2 Breach Type Taxonomy

Breach Type	Definition	Auto-Detected Signal	Example Trigger
Malware / Endpoint Risk	Malicious code execution or an unmanaged, potentially compromised endpoint	Unsigned installer, unusual process execution, EDR signature match	Installing unapproved or cracked software
Data Exfiltration	Company data leaving approved storage, tools, or systems	Outbound transfer to personal cloud, public AI tool, or screen capture in a sensitive session	Uploading files to a personal drive
Credential Compromise	Login credentials or secrets exposed, reused, or shared	Secret detected in a public repo, password shared in chat, anomalous login pattern	Committing an API key to GitHub
Device & Network Compliance Violation	Company data or network accessed from a non-compliant or non-company device	Login from a device outside MDM enrollment, Ethernet/HDMI bridge to an unmanaged device	Connecting a personal laptop to the office network
Policy Violation (Shadow IT)	Use of a tool or service outside the sanctioned catalog	Unrecognized application or domain in active use	Signing up for an unapproved SaaS tool

3. Common Security Risks & Preventive Controls

The eleven patterns below account for the large majority of avoidable internee-caused incidents. Each is auto-classified into a breach type and paired with the real-time response BreachMirror AI takes when it observes the behavior.

#	Risk Category	Breach Type	Examples	Impact if Exploited	BreachMirror AI Response
1	**Unauthorized Software Installation**	Malware / Endpoint	Cracked software, unvetted extensions, unreviewed open-source tools	Malware, ransomware, backdoors/spyware, data exfiltration	Blocks the install, flags the app as not IT-approved, routes to the Software Request Portal
2	**Sharing Confidential Data with Public AI Tools**	Data Exfiltration	Source code, customer data, internal docs, API keys, roadmaps	Data leaves the corporate environment, third-party retention, IP exposure	Scans the prompt, flags sensitive content as High risk, redirects to the approved AI platform
3	**Uploading Company Files to Personal Storage**	Data Exfiltration	Personal Google Drive, Dropbox, OneDrive, iCloud	Loss of organizational control, accidental sharing, data leakage	Blocks the transfer and recommends the approved company repository
4	**Using Personal Email for Company Work**	Data Exfiltration	Gmail, Yahoo, Hotmail used for business correspondence	Broken audit trail, data exposure, unauthorized forwarding	Detects the external domain and requires the corporate email account
5	**Public GitHub Repository Exposure**	Credential Compromise	Pushing source code, hard-coded API keys, committed config files	Credential leakage, IP theft, infrastructure compromise	Scans commits for secrets, warns on detection, recommends secret management
6	**Screenshot & Screen-Recording Risk**	Data Exfiltration	Capturing meetings, presentations, or customer information	Information leakage, unauthorized distribution	Detects capture during a sensitive session and surfaces the data-handling policy

#	Risk Category	Breach Type	Examples	Impact if Exploited	BreachMirror AI Response
7	**USB & External Device Usage**	Malware / Endpoint	Personal USB drives, external hard disks, unknown storage	Malware introduction, data theft, untracked transfers	Flags the unapproved device on connection and points to approved storage
8	**Visiting Untrusted Websites**	Malware / Endpoint	Crack sites, free-download portals, torrent sites, phishing pages	Malware infection, credential theft, browser exploits	Categorizes the site as high risk and blocks access
9	**Password Sharing**	Credential Compromise	Credentials shared over chat, email, or with colleagues	Account compromise, loss of accountability	Detects the credential-sharing pattern and points to approved access management
10	**Shadow IT**	Policy Violation	Unauthorized AI tools, personal cloud services, unapproved apps	Unsupported controls, regulatory violations, data exposure	Flags the unapproved service and redirects to the corporate application catalog
11	**Non-Company Device Usage**	Device Compliance	Personal laptop signed into company email; Ethernet or HDMI cable bridging a personal device to a company laptop, monitor, or the office network	Uncontrolled endpoint with no EDR/DLP, malware bridging onto the corporate network, uncontrolled screen/data capture	Blocks company email and account access from unenrolled devices, and flags any physical Ethernet/HDMI connection between a personal device and company hardware or network — company work is done on the company laptop only

Company-laptop-only rule: company email, files, and tools are used on the company-issued laptop only. Never sign into company accounts on a personal computer, and never physically connect a personal device to company hardware or the office network — including by Ethernet cable, HDMI, or any other cable.

4. Security Learning Recommendation Engine

Rather than simply blocking an action, BreachMirror AI pairs every intervention with a short, targeted explanation and an optional learning module — so the internee leaves the moment better equipped, not just stopped.

Incident: *Attempted upload of source code to a public AI chatbot*

Breach type: Data Exfiltration

Why it's risky: Uploading proprietary code may expose intellectual property and sensitive business logic to an external system outside company control.

Recommended module: "Safe Use of AI Tools" — 3 minutes

5. Security Awareness Score

Every internee carries a continuously updated score, built from policy compliance, training completion, risky-behavior trends, knowledge assessments, and improvement over time.

Score Range	Tier	Signal to Manager
90 – 100	**Excellent**	No action needed

Score Range	Tier	Signal to Manager
70 – 89	**Good**	Light-touch nudges
50 – 69	**Needs Improvement**	Assign refresher modules
0 – 49	**High Risk**	Manager review + mandatory training

This turns BreachMirror AI from a monitoring tool into a security awareness, education, and predictive breach-prevention system — internees learn what not to do, why it matters, and how to work securely from day one.

6. Agile Approach to Building & Maintaining This Documentation

This document and the underlying application are maintained together, in the same two-week Scrum cadence, so the documentation never drifts ahead of or behind what internees actually experience.

6.1 Cadence

- Sprint length: 2 weeks, with sprint review doubling as a documentation review — any shipped behavior change updates this document in the same sprint.
- Backlog owner: Product Owner, groomed weekly with input from the Security and Learning & Development stakeholders.
- Each epic below owns a section of this document; a change to the product triggers a change to that section, not a full rewrite.

6.2 Epics

- **Detection Engine** — the monitor-detect-classify-respond pipeline and breach-type taxonomy in Section 2.
- **Preventive Detection** — the eleven real-time controls in Section 3.
- **Device Compliance** — enforcement of the company-laptop-only rule, including Ethernet/HDMI bridging, in Section 3.
- **Learning Engine** — the in-the-moment explanations and module recommendations in Section 4.
- **Awareness Scoring** — the scoring model and manager signals in Section 5.
- **Prototype & UX** — the clickable alert, classification, and scoring experience used to validate tone and flow before engineering build.

6.3 Sample Sprint Backlog

ID	Epic	User Story	Priority	Sprint
US-1	Preventive Detection	As an internee, I want to be warned before installing unapproved software so that I don't accidentally introduce malware.	**High**	Sprint 1
US-2	Preventive Detection	As a security admin, I want sensitive-content detection on public-AI-tool prompts so confidential data never leaves the org.	**High**	Sprint 1
US-3	Detection Engine	As a security admin, I want every flagged event auto-classified into a breach type so response and reporting are consistent.	**High**	Sprint 1
US-4	Device Compliance	As a security admin, I want company accounts blocked on any device outside MDM enrollment, including over Ethernet/HDMI bridges, so company data never leaves company hardware.	**High**	Sprint 2
US-5	Learning Engine	As an internee, I want a short learning module recommended right after a risky action so I understand why it's dangerous.	**Medium**	Sprint 2
US-6	Awareness Scoring	As an internee, I want my awareness score to visibly improve after completing training so I stay motivated to learn.	**Medium**	Sprint 3
US-7	Awareness Scoring	As a manager, I want to see my team's aggregate awareness scores so I can target coaching where it's needed.	**Medium**	Sprint 3

ID	Epic	User Story	Priority	Sprint
US-8	Prototype & UX	As a product owner, I want a clickable prototype of the alert and scoring experience so we can validate tone before build.	**High**	Sprint 1

6.4 Definition of Done

- The behavior is demoable in the prototype or product build, not just described.
- The corresponding section of this document is updated in the same sprint and reflects the shipped copy verbatim.
- The risk, breach type, example set, and system response have been reviewed by the Security stakeholder.
- The change is logged in the Change Log (page 1) with version, date, and a one-line summary.

6.5 Documentation Versioning

This document follows Major.Minor versioning: a Major version marks a new epic or a change to the detection or scoring model; a Minor version marks additions or wording changes within an existing epic. Every release — product or documentation-only — gets a Change Log entry, so any reader can see exactly what changed and why without diffing the whole file.